

ISE 331: Fundamentals of Computer Security

Practice Problems for Cryptography: Lecture 03 to Lecture 08

Directions: Below is a set of exercises and problems you should do for practice. Answering this set of questions should be just one part of your preparation for quizzes and exams. In addition to solving these problems you should:

- Review the lecture notes.
- Review your homework assignments.
- Form a study group and test each other on the material.

Note: The solution is provided on the last page. It is strongly recommended that you work on the questions first before going to the solution.

Part I. Multiple Choice

1. Which of the following is necessary for the One-Time Pad to achieve perfect confidentiality?
A. Every possible key must be equally likely.
B. The key must be reused for multiple messages.
C. The cipher must operate on fixed-size blocks of data.
D. The key must be generated by a pseudo-random number generator (PRNG).
2. Which is NOT a property of modern symmetric encryption using block cipher?
A. Sender and receiver share the same key
B. Can not be brute forced
C. Ciphertext does not reveal plaintext
D. Reversible with the correct key
3. Alice writes down the hash values of all her important documents. Assume that she is using a secure hash function. Which of the following is probably true?
A. If her documents are deleted, she can recover her documents from the hash values.
B. If she has a few hundred documents, she has a high chance of discovering two hash values being the same.
C. If her documents are modified, she can notice by checking the new hash values against the old ones.
D. If two of her documents are similar, their hash values will also be similar.
4. A developer is designing a system to store user passwords on a server. They recall that both encryption and hashing can be used to store the passwords. Which of the following statements best explains why hashing is preferred over encryption?
A. Hashing generates fixed length data, but the ciphertext can have different lengths.
B. Encrypted password can be recovered with a key, but hashed password cannot be recovered.
C. Ciphertexts for the same password can be different, but hashing the same password always gives the same result.
D. Encryption of passwords may be slow for a secure encryption algorithm, but hashing of passwords is always fast.
5. Bob is trying to send a 10GB file to Alice efficiently, and he wants the file to remain confidential. Which is the best option?
A. Send a key to Alice, use symmetric encryption to encrypt the file, and send the ciphertext
B. Exchange a key with Alice with key exchange protocol, then use symmetric encryption to encrypt the file, send ciphertext
C. Sign the file with Digital Signature Algorithm, and send the file in plaintext
D. Send the file with asymmetric encryption
6. Alice and Bob want to send messages to each other with asymmetric encryption. Which statement below is correct?
A. Alice needs to use her secret key to encrypt her message to Bob.
B. Bob needs to use his secret key to verify Alice's public key.
C. Alice needs to use both public keys to send and receive messages.
D. Bob needs to use his secret key to decrypt Alice's message.

7. The Diffie-Hellman protocol is primarily used to:
- A. Create a shared secret over insecure channel.
 - B. Generate a random number for symmetric encryption.
 - C. Sign a message to prove its origin.
 - D. Encrypt long messages in blocks.
8. A malicious attacker obtained a root Certificate Authority's private key. Which of the following is correct?
- A. The attacker can revoke all certificates issued by the root CA.
 - B. The attacker can sign certificates for his own websites as the root CA.
 - C. The attacker can decrypt all messages using a certificate from the root CA.
 - D. The attacker can modify the public keys of the root CA.
9. Which prevents Man-in-the-Middle attack in asymmetric encryption?
- A. The attacker cannot use the public keys of the CAs.
 - B. The CAs will not sign the attacker's public key.
 - C. The clients will only use the CA's public key.
 - D. The attacker cannot obtain the CA's private key.
10. TLS is not used for:
- A. Determine key exchange algorithm
 - B. Send certificates signed by CAs
 - C. Establish symmetric encryption communication
 - D. Sending account ID and password for login

Part II. True or False

1. The security of the One-Time Pad is based on the assumption that no efficient algorithm exists to break it within reasonable time.
2. For modern block ciphers, a change of one bit in the plaintext will result in the change of one random bit in the ciphertext.
3. Unlike symmetric encryption, hash functions do not require a secret key to compute the result.
4. Using Encrypt-and-MAC (sending both the ciphertext and a MAC of the plaintext) guarantees both confidentiality and integrity of the message.
5. A cryptographic hash function that provides 256 bits of output, like SHA-256, offers 256 bits of security against collision attacks. This means an attacker would need to perform approximately 2^{256} operations to find a collision.
6. In asymmetric encryption, if an attacker obtained Alice's secret key, the attacker can sign a message as if it is sent by Alice.
7. The root Certificate Authorities (root CAs) are responsible for signing all website certificates.
8. Websites like Baidu and Taobao will not send you messages unless you send them valid certificates first.
9. TLS is responsible for protecting both the confidentiality and integrity of the messages.
10. Current TLS supports multiple symmetric encryption and message authentication algorithms.

Part III. Short Answer

1. For a block cipher, the Electronic Code Book (ECB) mode just separate the plaintext into equal-sized blocks, encrypt them with the same key, and concatenate the ciphertext blocks. This operation mode has a security weakness. Explain the cause and danger of this weakness.
2. Alice sends a plaintext p and its hash value h ($h = h(p)$) to Bob on the channel. The hash function is a secure hash function, like SHA-256. Bob receives p and h , he calculates $h' = h(p)$ himself. Seeing that $h' = h$, he thinks that p is not modified in transit. Can this method be used to protect the integrity of p against an attacker that can modify what's on the channel? Explain.
3. Asymmetric encryption is known to need much longer keys to reach the same level of security compared to symmetric encryption. Explain why we still use asymmetric encryption.
4. A server uses salt for password storage. The salt s is a random bit sequence. h is a secure hash function. The server performs calculation: $r = s \mathbf{XOR} h(\text{password})$, and store r with s in their database. Does this prevent an offline attacker from performing a dictionary attack?
5. What is a "Trapdoor One-Way Function," and how does it relate to asymmetric encryption?

Part IV. Calculation

1. The standard Data Encryption Standard (DES) uses a 56-bit key. A hacker can brute-force all possible keys in 1 day. Assume all conditions remain the same, how long can this hacker brute-force all possible keys if the algorithm uses 112-bit keys instead? Use the approximation $2^{10} \approx 10^3$.

Part I Solution:

1-5 ABCBB 6-10 DABDD

Part II Solution:

1-5 FFTFF 6-10 TFFT

Part III Solution:

1. The main weakness in the ECB mode is that identical plaintext blocks will encrypt to identical ciphertext blocks, revealing statistical information of the plaintext.
2. No, following Kerckhoff's principle, the attacker also knows the hash function. He can just modify p to his own p'' , and modify h to his own h'' , $h'' = h(p'')$. Bob will not notice anything wrong upon receiving p'' and h'' , since his calculation of $h(p'')$ will be h'' .
3. Symmetric encryption requires the two subjects to share a common secret before communicating, which is difficult in practice. Asymmetric encryption enables the sharing of a common secret even with an eavesdropper.
4. No. Salt is stored as plaintext, and the attacker can precompute rainbow table. Upon breaking into the server, he just needs to perform calculation $r \mathbf{XOR} s$, which is $h(\text{password})$, then perform dictionary attack. XOR operation is very easy to perform and takes little time, so the time for the attack is not significantly extended.
5. It is a function that is easy to compute but difficult to reverse unless you have a specific piece of extra information (the "trapdoor"). In asymmetric encryption, the public key is the function, and the private key is the trapdoor.

Part IV Solution:

1. Assume that the hacker uses x seconds to test one key combination, we have:

$$x \times 2^{56} = 1 \text{ day}$$

To brute force all possible keys for a 112-bit key, the time will be:

$$x \times 2^{112} = x \times 2^{56} \times 2^{56} = 2^{56} \text{ days} \approx 3.2 \times 10^{16} \text{ days}$$

$$2^6 \times 10^{15} = 6.4 \times 10^{16}$$